

Project 3: Phishing Awareness Analysis

DecodeLabs Cyber Security Internship (Batch 2026)
Submitted by: Malik Daniyal Ahmed

1. Objective

The goal of this project is to analyze sample emails to identify phishing attempts, list the specific red flags present, and explain why each message is unsafe. This builds threat-identification skills that sit alongside technical firewalls as part of the 'human firewall'.

2. Method

Three sample messages were reviewed: two constructed phishing emails and one legitimate internal email for comparison. Each was analyzed manually against known phishing indicators (urgency, fear/greed appeals, requests for sensitive data, lookalike domains, sender/domain mismatch) and also passed through a rule-based Python analyzer (phishing_analyzer.py) that automatically flags these same patterns.

3. Sample Analysis

Sample 1 — Fake Microsoft Account Suspension

From: Microsoft Support <support@login-updates.xyz>

Subject: URGENT: Your Account Will Be Suspended

Dear user, we detected unauthorized access to your account. You must verify your account immediately by clicking the link below, or your account will be locked within 24 hours.
<http://microsoft-secure-login.xyz/verify?id=88291>

Verdict: LIKELY PHISHING

- Urgency language: 'urgent', 'immediately', '24 hours', 'locked', 'unauthorized'.
- Sender display name says 'Microsoft Support' but the domain is login-updates.xyz — a mismatch.
- Link uses a suspicious .xyz top-level domain and combines the brand name 'microsoft' with extra hyphenated words, a classic lookalike-domain pattern.

Why it's unsafe: The message pressures the reader into acting before thinking, and the link does not actually belong to Microsoft. Clicking it would likely lead to a credential-harvesting login page.

Sample 2 — Fake Prize / PayPal Credential Harvest

From: Bank Alert <alerts@paypal-secure-verify.top>

Subject: You Have Won a Prize! Claim Your Reward Now

Congratulations! You have won a \$500 gift card. Claim your prize now by entering your credit card details and OTP at:
www.paypal-account-check.top/claim

Verdict: LIKELY PHISHING

- Greed appeal: 'you have won', 'prize', 'claim your', 'reward'.
- Directly requests sensitive information: credit card number and OTP.
- Sender claims to be a 'Bank Alert' but is sent from a paypal-secure-verify.top domain — unrelated to both PayPal and any real bank.
- Link uses a .top domain combined with 'paypal' in the subdomain, another lookalike pattern.

Why it's unsafe: No legitimate company asks for a one-time password or full card details by email. The 'prize' framing is designed to trigger excitement and bypass careful review, and the domain does not belong to PayPal.

Sample 3 — Legitimate Internal Email

From: Sarah Lee <sarah.lee@decodelabs.tech>

Subject: Q3 Project Status Update

Hi team, please review the attached project status for Q3 at your earliest convenience. No immediate action is required.
Thanks, Sarah

Verdict: SAFE

- No urgency or pressure language.
- No links or requests for sensitive information.
- Sender's display name matches the email domain (decodelabs.tech), and the tone is routine and low-pressure.

Why it's unsafe: This message has none of the manipulation patterns seen in the phishing samples — it is included as a baseline to show what a normal, low-risk email looks like.

4. Consolidated Red Flag Checklist

- Urgency or threats ('act now', 'account suspended', 'within 24 hours').
- Unexpected requests for passwords, OTPs, PINs, or card details.
- Sender display name doesn't match the actual email domain.
- Links using unusual top-level domains (.xyz, .top, .click) or brand names mixed with extra hyphenated words.
- Emotional triggers such as fear, greed, or curiosity used to rush a decision.

5. Conclusion

Both phishing samples combined a psychological trigger with a technical disguise, while the legitimate sample showed neither. The golden rule for handling any suspicious message is to Pause, Verify (through a separate trusted channel), and Report rather than clicking or replying directly. Building this analytical habit is a foundational skill for bridging the gap between human error and system security.